

# PayCloud Payroll System

**Owner:** Praneesh R V  
**Reviewer:**  
**Contributors:**  
**Date Generated:** Tue Jul 21 2026

# Executive Summary

## High level system description

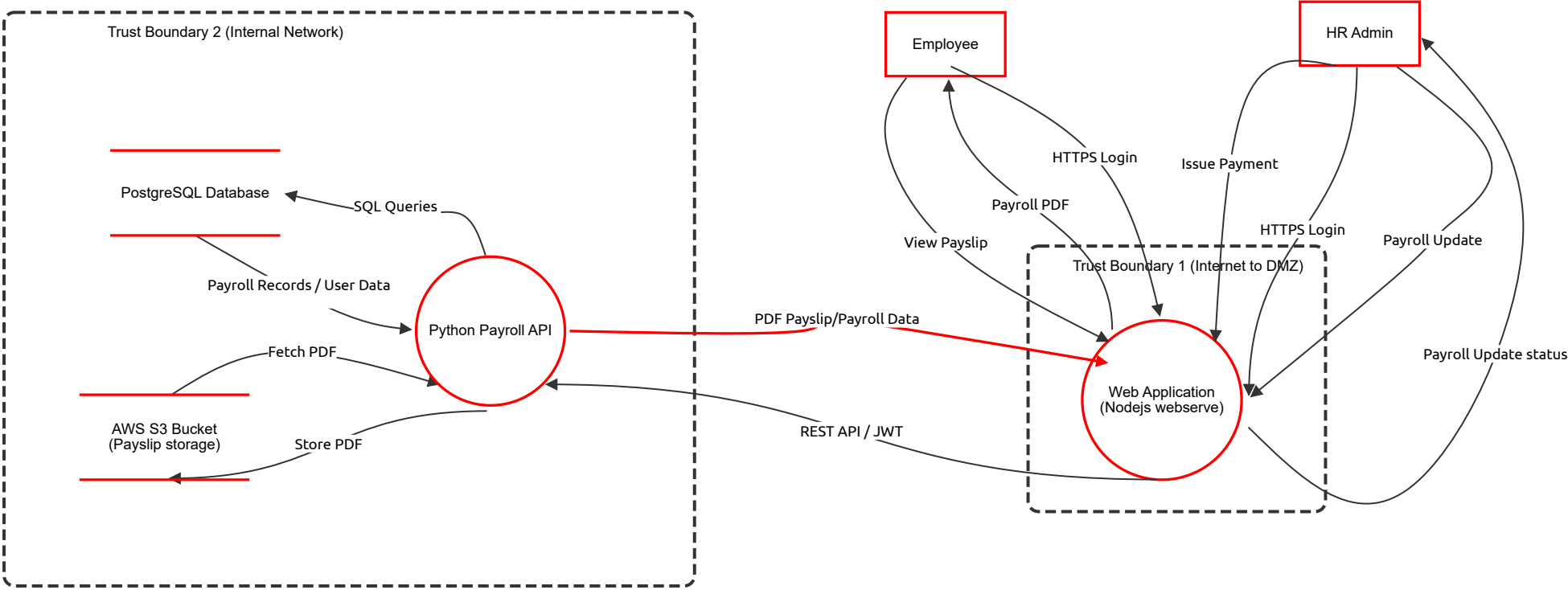
PayCloud is a cloud-based payroll management system that enables employees to securely view payslips and HR administrators to upload payroll data and issue salary payments. The system processes sensitive Personally Identifiable Information (PII) and financial data through a secure multi-tier architecture consisting of a web application, backend API, relational database, and cloud document storage.

## Summary

|                          |    |
|--------------------------|----|
| Total Threats            | 10 |
| Total Mitigated          | 0  |
| Total Open               | 10 |
| Open / Critical Severity | 3  |
| Open / High Severity     | 6  |
| Open / Medium Severity   | 1  |
| Open / Low Severity      | 0  |

# PayCloud Payroll DFD

cloud-based payroll management system



# PayCloud Payroll DFD

## Employee (Actor)

| Number | Title                        | Type     | Severity | Status | Score | Description                                                                                                                                                                     | Mitigations                                                                                                                                                                                                  |
|--------|------------------------------|----------|----------|--------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1      | User Authentication Spoofing | Spoofing | High     | Open   |       | An attacker may use stolen employee or HR administrator credentials to impersonate a legitimate user and gain unauthorized access to the payroll system through the login page. | Implement Multi-Factor Authentication (MFA), enforce strong password policies, use HTTPS, store passwords using salted hashing (bcrypt), and implement account lockout after repeated failed login attempts. |

## HR Admin (Actor)

| Number | Title                        | Type        | Severity | Status | Score | Description                                                                                                                                                                     | Mitigations                                                                                                                                                                                                  |
|--------|------------------------------|-------------|----------|--------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 3      | User Authentication Spoofing | Spoofing    | High     | Open   |       | An attacker may use stolen employee or HR administrator credentials to impersonate a legitimate user and gain unauthorized access to the payroll system through the login page. | Implement Multi-Factor Authentication (MFA), enforce strong password policies, use HTTPS, store passwords using salted hashing (bcrypt), and implement account lockout after repeated failed login attempts. |
| 8      | Payroll Update Repudiation   | Repudiation | Medium   | Open   |       | An HR administrator may deny performing payroll updates or issuing payments because there is no reliable audit trail recording user activities.                                 | Maintain secure audit logs with timestamps, record user IDs and IP addresses, protect logs from modification, and regularly review audit records.                                                            |

## Web Application (Nodejs webserver) (Process)

Description: A Node.js web server hosted in a public cloud DMZ. It serves the UI, handles user authentication, and routes requests.

| Number | Title                                     | Type              | Severity | Status | Score | Description                                                                                                                                                               | Mitigations                                                                                                                                                        |
|--------|-------------------------------------------|-------------------|----------|--------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7      | Payroll Data Tampering                    | Spoofing          | High     | Open   |       | An attacker may modify payroll requests or API messages between the Web Application and Payroll API, resulting in unauthorized salary or payment changes.                 | Protect communication using HTTPS/TLS, validate JWT tokens, perform server-side input validation, digitally sign sensitive requests, and verify request integrity. |
| 10     | Denial of Service Against Web Application | Denial of service | High     | Open   |       | An attacker floods the Web Application with excessive login or API requests, exhausting server resources and preventing legitimate users from accessing payroll services. | Implement rate limiting, deploy a Web Application Firewall (WAF), enable autoscaling, monitor traffic continuously, and block suspicious IP addresses.             |

## Store PDF (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## Fetch PDF (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## Issue Payment (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|        |       |      |          |        |       |             |             |

## REST API / JWT (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|        |       |      |          |        |       |             |             |

## Payroll Records / User Data (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|        |       |      |          |        |       |             |             |

## SQL Queries (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|        |       |      |          |        |       |             |             |

## View Payslip (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|        |       |      |          |        |       |             |             |

## HTTPS Login (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|        |       |      |          |        |       |             |             |

## PDF Payslip/Payroll Data (Data Flow)

| Number | Title                  | Type      | Severity | Status | Score | Description                                                                                                                                               | Mitigations                                                                                                                                                        |
|--------|------------------------|-----------|----------|--------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 12     | Payroll Data Tampering | Tampering | High     | Open   |       | An attacker may modify payroll requests or API messages between the Web Application and Payroll API, resulting in unauthorized salary or payment changes. | Protect communication using HTTPS/TLS, validate JWT tokens, perform server-side input validation, digitally sign sensitive requests, and verify request integrity. |

## HTTPS Login (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|        |       |      |          |        |       |             |             |

## Payroll PDF (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|        |       |      |          |        |       |             |             |

## Payroll Update (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## Payroll Update status (Data Flow)

| Number | Title | Type | Severity | Status | Score | Description | Mitigations |
|--------|-------|------|----------|--------|-------|-------------|-------------|
|--------|-------|------|----------|--------|-------|-------------|-------------|

## Python Payroll API (Process)

Description: A Python-based API server hosted on a private cloud subnet. It processes business logic, calculates tax deductions, and enforces role-based access controls (RBAC).

| Number | Title                             | Type                   | Severity | Status | Score | Description                                                                                                                                                 | Mitigations                                                                                                                                                          |
|--------|-----------------------------------|------------------------|----------|--------|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 6      | Payroll Data Tampering            | Spoofing               | High     | Open   |       | An attacker may modify payroll requests or API messages between the Web Application and Payroll API, resulting in unauthorized salary or payment changes.   | Protect communication using HTTPS/TLS, validate JWT tokens, perform server-side input validation, digitally sign sensitive requests, and verify request integrity.   |
| 11     | Unauthorized Privilege Escalation | Elevation of privilege | Critical | Open   |       | A normal employee exploits weak authorization checks in the Payroll API to access HR administrator functions such as payroll updates or payment processing. | Enforce Role-Based Access Control (RBAC), validate authorization on every API request, apply the principle of least privilege, and perform regular security testing. |

## PostgreSQL Database (Store)

Description: A PostgreSQL database in a restricted database subnet. It stores user credentials, salary details, and personal identification numbers.

| Number | Title                                    | Type                   | Severity | Status | Score | Description                                                                                                                                                           | Mitigations                                                                                                                                                                               |
|--------|------------------------------------------|------------------------|----------|--------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 9      | Sensitive Payroll Information Disclosure | Information disclosure | Critical | Open   |       | Sensitive employee information, salary records, or PDF payslips stored in PostgreSQL or the S3 bucket may be exposed because of insecure permissions or data leakage. | Encrypt data at rest and in transit, configure least-privilege access controls, secure S3 bucket permissions, encrypt database backups, and mask sensitive information where appropriate. |

## AWS S3 Bucket (Payslip storage) (Store)

Description: An AWS S3 bucket (Data Store) that holds generated PDF payslips. The API server fetches these and passes them to the Web Application.

| Number | Title                                    | Type      | Severity | Status | Score | Description                                                                                                                                                           | Mitigations                                                                                                                                                                               |
|--------|------------------------------------------|-----------|----------|--------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 13     | Sensitive Payroll Information Disclosure | Tampering | Critical | Open   |       | Sensitive employee information, salary records, or PDF payslips stored in PostgreSQL or the S3 bucket may be exposed because of insecure permissions or data leakage. | Encrypt data at rest and in transit, configure least-privilege access controls, secure S3 bucket permissions, encrypt database backups, and mask sensitive information where appropriate. |